Investigación y Aplicación de metodologías de Seguridad Informática para el Fortalecimiento de la Seguridad Operativa de usuarios Windows.

Duarte P. Jhon

***Resumen* — La seguridad informática es un tema que nos ha dejado mucho de qué hablar en los últimos años. Los diferentes ataques masivos emitidos a los equipos cliente nos han dejado resultados bastante preocupantes. Fotos comprometedoras de grandes famosos filtradas en las redes de internet, la captura masiva de información para solicitar dinero, y programas espía en una gran cantidad de equipos son algunos ejemplos que nos ha dado la baja conciencia de los usuarios sobre los riesgos existentes al usar una computadora con sistema operativo Windows. Con base en esto, se propuso una investigación en la cual se vea reflejada el cómo entra un atacante a una computadora personal, cómo puede descifrar contraseñas a través de algoritmos de búsqueda, que tipo de control se puede obtener a través del ataque, que clase información se puede robar con el mismo y, de esa manera, plantear una metodología de prevención al usuario para hacer el acceso más difícil al atacante.**

***Abstract* —Computer security is a topic that has left us much to talk about in recent years. The different massive attacks issued to client computers have left us with quite worrying results. Engaging photos of big celebrities filtered on internet networks, the massive capture of information to request money, and spyware on a large number of computers are some examples that have given us the low awareness of users about the risks that exist when using a computer with Windows operating system. Based on this, an investigation was proposed in which it is reflected how an attacker enters a personal computer, how it can decipher passwords through search algorithms, what kind of control can be obtained through the attack, what class information can be stolen with it and, in that way, pose a prevention methodology to the user to make access more difficult to the attacker..**

I. INTRODUCCIÓN

No se tiene conocimiento de un artículo o ponencia investigativa que tenga como prioridad la seguridad de los datos de los usuarios en el uso de sistemas operativos Windows. El proyecto a realizar plantea una solución a la falta de conocimiento y/o conciencia que tiene un usuario final en cuanto al funcionamiento de la seguridad de su equipo personal bajo las siguientes premisas: Hacer una investigación a través de diferentes recursos de internet en la cual se logre mostrar cuál es la anatomía de un ataque informático, exhibir las principales vulnerabilidades del sistema operativo Windows, visualizar las herramientas de software por las cuales se efectúa un ataque informático a este sistema operativo y orientar a los usuarios sobre éstos para la prevención de los mismos.

II. ANATOMÍA DE UN ATAQUE INFORMÁTICO

Los ataques informáticos contienen ciertas etapas que los llevan a ser efectivos, estos son:

A. Reconocimiento, que es una fase preparatoria utilizada para reunir más información sobre el objetivo.
B. Escaneo, que es la fase previa al ataque para encontrar la información básica.
C. Obtener acceso, la primera fase de penetración, utilizada para encontrar agujeros en el sistema y obtener acceso a información altamente detallada.
D. Mantener el acceso, en el cual los intrusos establecen control en un nivel de propiedad, dejando parte de su presencia en el sistema para ganar acceso a voluntad.
E. Limpiar sus pistas, en las cuales los intrusos esconden rastros de su actividad mediante la eliminación evidenciada de los registros del sistema. [1]

La metodología usada se muestra en la figura 1.

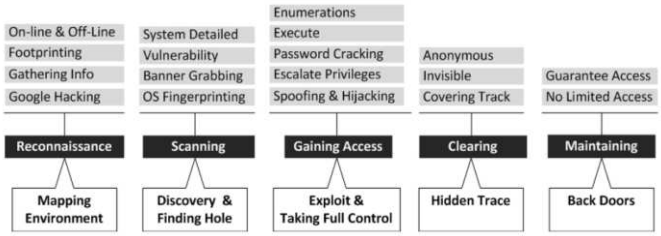

Fig. 1. Fases de un ataque informático

A. *Reconocimiento.*

Esta etapa involucra la obtención de información con respecto a una potencial víctima que puede ser una persona u organización. La recopilación de información incluye la búsqueda de información básica útil, como la dirección IP, la

red de topología, los recursos de red e incluso la información personal del usuario, que se puede utilizar en el siguiente paso. Los motores de búsqueda se utilizan generalmente para obtener información de recursos en línea, mientras que la recopilación de información fuera de línea se logra reuniendo piezas dispersas de información junto con la ingeniería social para consolidar una gran cantidad de datos que se pueden utilizar para realizar reconocimientos de un ambiente objetivo. Por lo general, durante esta fase se recurre a diferentes recursos de Internet como Google, entre tantos otros, para recolectar datos del objetivo.

B. Exploración.

En esta segunda etapa se utiliza la información obtenida en la fase A para sondear el blanco y tratar de obtener información sobre el sistema víctima como direcciones IP, nombres de host, datos de autenticación, entre otros. Las acciones que forman la mayoría de las sondas de información incluyen probar un sistema para tipos de respuesta, escaneo de puertos y probar el sistema enviando varias consultas al objetivo.
El flujo de acuse de recibo se puede resolver observando los mensajes de falla que regresan a un sistema cuando se ha detectado un problema de entrega. Los objetivos de esta etapa son descubrir dónde el objetivo es más vulnerable, dicha información se puede usar junto con la base de datos de notas de vulnerabilidades CERT, CVE (Lista de vulnerabilidades y exposiciones comunes), metasploit y la comunidad de seguridad (CVE, Security Focus, Base de datos nacional de vulnerabilidades, Secunia, Microsoft Security Bulletin y Exploit search) para determinar la mejor forma de obtener acceso a las máquinas de segmentación previstas.

C. Obtener acceso.

En esta instancia comienza a materializarse el ataque a través de la explotación de las vulnerabilidades y defectos del sistema descubiertos durante las fases de reconocimiento y exploración. A partir de ahí, obtener acceso a la víctima prevista se logra mediante la penetración directa a través de adivinación de contraseñas, que incluye intentar iniciar sesión en conexiones SSH, FTP, Telnet o HTTP utilizando el acceso de instalación predeterminado, combinado con intentos de contraseña de fuerza bruta tales como: Desbordamiento de búfer, denegación de servicio (DoS), denegación de servicio distribuida (DDos), filtrado de contraseña y secuestro de sesión. Los atacantes decididos también pueden ejecutar el rastreo de paquetes o intentar observar el proceso de autenticación del sistema capturando la actividad que se produce entre la máquina objetivo y el cliente.

D. Mantener el acceso.

Una vez que el atacante ha conseguido acceder al sistema, buscará implantar herramientas que le permitan volver a acceder en el futuro desde cualquier lugar donde tenga acceso a Internet. Es común implantar malware, netbus y subseven para crear una puerta trasera a fin de garantizar el acceso total. La instalación normalmente se realiza a través de un puerto de red apenas utilizado para evitar el aviso. El acceso de puerta trasera (backdoor) es muy útil para mantener el acceso al sistema sin tener que empezar de cero, así como para evitar el registro de grabación y los operadores de seguridad.

E. Limpieza.

Una vez que el atacante logró obtener y mantener el acceso al sistema, intentará borrar todas las huellas que fue dejando durante la intrusión para evitar ser detectado por el profesional de seguridad o los administradores de la red. En consecuencia, buscará eliminar los archivos de registro (log) o alarmas del Sistema de Detección de Intrusos (IDS). [3][4].

III. PUERTOS

Un puerto de red es una construcción de software específica de un proceso o aplicación que sirve como punto final de comunicación, que es utilizado por los protocolos de la capa de transporte del conjunto de protocolos de Internet, como el protocolo de diagrama de usuario (UDP) y el protocolo de control de transmisión (TCP). Un puerto de red específico se identifica por su número comúnmente denominado número de puerto, la dirección IP con la que está asociado el puerto y el tipo de protocolo de transporte utilizado para la comunicación. Un número de puerto es un entero sin signo de 16 bits que va de 0 a 65535. Se podría asignar una dirección de puerto para hablar con procesos o dispositivos externos. Un proceso o dispositivo de red utiliza un puerto de red específico para transmitir y recibir datos. Esto significa que escucha los paquetes entrantes cuyo puerto de destino coincide con ese número de puerto y/o transmite los paquetes salientes cuyo puerto de origen se establece en ese número de puerto. [5]

Los diferentes artículos realizados han planteado maneras de ver los ataques informáticos, sin embargo, el autor [2] describió los diez (10) puertos más frecuentes a los cuales van dirigidos estos ataques. Ellos son: SSH port (22), Web (80), RPC (135), HTTPS (443), SMB (445), Microsoft SQL (1433), MySQL (3306), desconocido/potencial malware (8443, 12174, 6000).

IV. ALGORITMOS DE BÚSQUEDA EN TEXTOS

La búsqueda de textos a través de algoritmos se genera a través de patrones en los caracteres del texto, Las aplicaciones de estos algoritmos son variadas, desde encontrar una palabra especifica en algún archivo de texto o solucionar problemas relacionados a la biología computacional (la cual requiere una búsqueda de patrones a través de secuencias ADN).

A. Algoritmo Knuth-Morris-Pratt

La primera aproximación de solución es por Fuerza Bruta, es decir, por cada posición en la cadena de caracteres revisar si el patrón aparece. Un algoritmo de String Matching que convierte el patrón de búsqueda en una máquina de estado finito, y luego ejecuta esta máquina en la cadena de entrada.

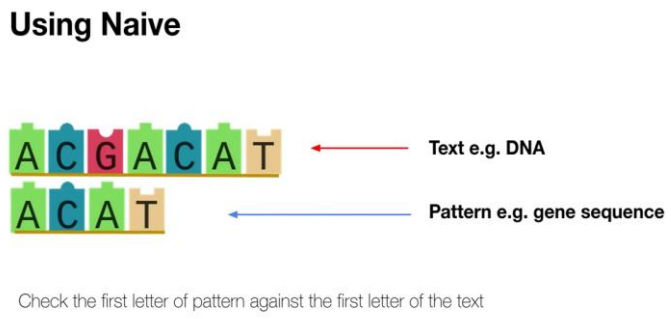

Fig. 2. Funcionamiento del algoritmo Knuth-Morris-Pratt.

B. *Algoritmo Boyer-Moore-Horspool.*

El algoritmo BMH compara el patrón con el texto de derecha a izquierda, y se detiene cuando se encuentra una discrepancia con el texto. Se calcula la distancia mínima entre el último carácter y la ocurrencia de cada carácter del alfabeto de la hilera principal.

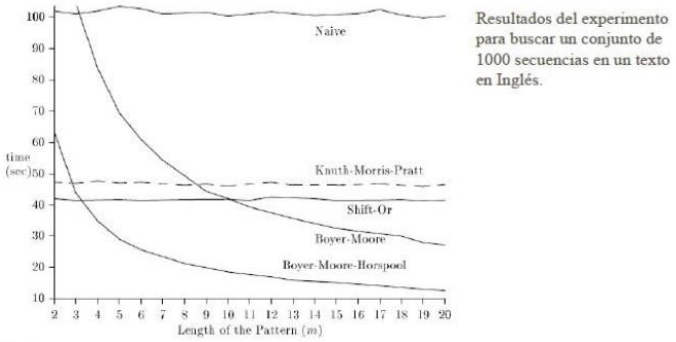

Fig. 3. Funcionamiento del algoritmo BMH.

C. *Algoritmo de Fuerza bruta.*

Se alinea la primera posición del patrón con la primera posición del texto, y se comparan los caracteres uno a uno hasta que se acabe el patrón, esto es, se encontró una ocurrencia del patrón en el texto, o hasta que se encuentre una discrepancia. Si se detiene la búsqueda por una discrepancia, se desliza el patrón en una posición hacia la derecha y se intenta calzar el patrón nuevamente.

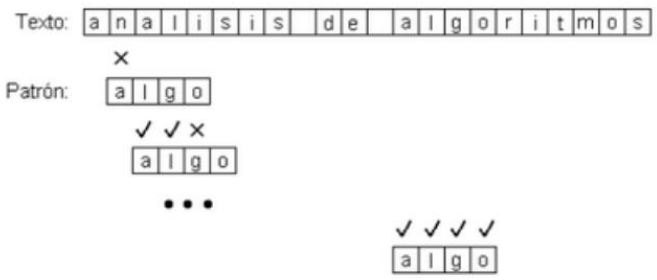

Fig. 4. Funcionamiento del algoritmo de Fuerza Bruta

En el peor caso este algoritmo realiza todas las comparaciones de caracteres posibles.

V. Métodos de Aplicación

A. *Metasploit.*

Metasploit Framework es una plataforma para escribir, probar y utilizar código de explotación. Los usuarios principales del Marco son profesionales que realizan pruebas de penetración, desarrollo de código de shell e investigación de vulnerabilidades. [5]

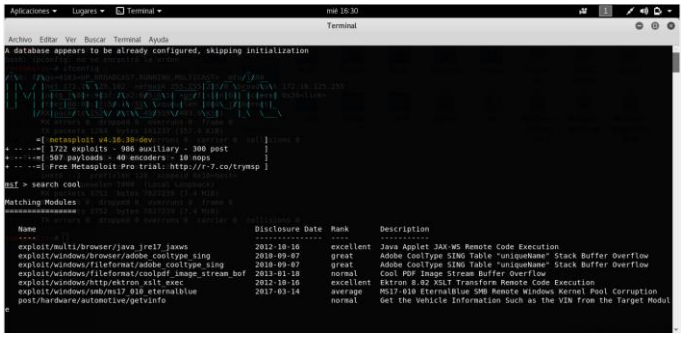

Fig. 4. Interfaz principal Metasploit.

B. *Ataque de Fuerza bruta mediante Diccionario.*

Es una técnica de violación de contraseñas en la cual se prueban consecutivamente palabras del diccionario para validar una clave o contraseña.

Generalmente las personas emplean palabras de uso común en su idioma para construir claves fáciles de recordar; si bien esto facilita el trabajo a la memoria del usuario, lo hace también para los atacantes quienes, empleando un ataque de diccionario podrían con relativa facilidad quebrantar la seguridad de la clave del usuario. [6]

VI. Aplicación de Métodos

A. *Intrusión mediante Puertos.*

Mediante la herramienta metasploit, se genera un script que va al equipo víctima del ataque. Estos archivos no son perceptibles a simple vista, pues están camuflados detrás de archivos comunes. En este caso, se usó un pdf para poderse ejecutar. Una vez abierto el archivo, se ejecuta un proceso en segundo plano y se abre un puerto trasero que apunta hacia el equipo del atacante. Tan pronto se establezca esta comunicación, el atacante obtiene el control total sobre el equipo mientras este esté encendido, y puede acceder y encriptar la información de la víctima según el objetivo del ataque.

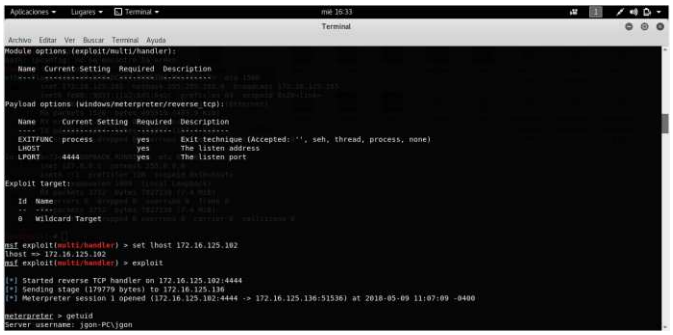

Fig. 5. Interfaz conectada para el ataque

B. Obtención de Clave por Fuerza Bruta.

Hay dos tipos de diccionarios: El primero se construye mediante Ingeniería Social[1] y el segundo mediante todas las combinaciones posibles de una contraseña. Para esta investigación se toma como objetivo una cuenta en Gmail y se toma un diccionario con todas las contraseñas más comunes obtenidas a través de la Ingeniería Social. Con esto en base, el atacante ejecuta el ataque y sólo tiene que esperar hasta que una de las contraseñas de su diccionario coincida con la contraseña de la cuenta y así puede acceder a la misma desde cualquier lugar (siempre y cuando esta contraseña no sea cambiada).

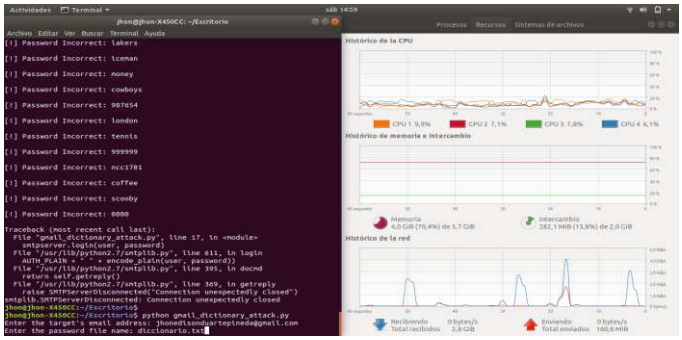

Fig. 6. Lanzamiento de ataque con fuerza bruta.

VII. CONCLUSIÓN

La seguridad de una persona viene desde casa. Para prevenir los ataques por invasión de puertos, siempre se debe escribir en el navegador la dirección a la que se quiere acceder[2], escribir contraseñas complejas[3] y verificar el certificado de 'sitio seguro' cuando se intercambia información en la web.

La seguridad de los usuarios es lo más importante en esta investigación. Por lo tanto, la metodología de explicar cómo se vulnera un sistema y cómo defenderse de ella hace de este artículo una guía comprensible para un usuario en general del cómo asegurar su equipo y sus cuentas.

RESULTADOS OBTENIDOS.

Las personas pueden usar este artículo como guía para poder prevenirse de ataques informáticos.

Analizando los costes computacionales, una intrusión a los puertos es mucho más eficaz en el tema de recursos del sistema. Sin embargo, los algoritmos de fuerza bruta suelen ser muy efectivos a la hora de obtener contraseñas de los usuarios, sacrificando los recursos del sistema del atacante.

Gracias a esto, se genera una mejor cultura sobre la seguridad de las personas en la red y se previenen robos y pérdidas de información, que es lo más importante de los usuarios.

AGRADECIMIENTOS

Agradezco profundamente a la Universidad Autónoma de Bucaramanga por permitirme efectuar esta investigación, al docente en Sistemas, Ing. Gerson Paredes Dávila, al docente Mtr. Ariel Orlando Ortiz Beltrán, y a mis compañeros de curso que me guiaron en el desarrollo de este proyecto.

De igual manera, agradezco a todos mis compañeros de universidad, familiares y docentes institucionales que me apoyaron en el transcurso de la misma.

VIII. REFERENCIAS

[1] W. Kim, O.-R. Jeong, C. Kim y J. So, «The dark side of the Internet: Attacks, costs and responses,» *Information Systems,* vol. vol. 36, pp. 675-705, 2011.

[2] M. Molina, I. Paredes-Oliva, W. Routly y P. Barlet-Ros, «Operational experiences with anomaly detection in backbone networks,» *Computers & Security,* vol. vol. 31, pp. 273-285, 2012.

[3] J. Mieres, «Ataques informáticos. Debilidades de seguridad comúnmente explotadas.,» Evil Fingers, Enero 2009. [En línea]. Available: https://www.evilfingers.com/publications/white_AR/01_Ataques_informaticos.pdf. [Último acceso: 14 Marzo 2018].

[4] D. Stiawan, M. Y. Idris, A. H. Abdullah, F. Aljaber y R. Budiarto, «Cyber-Attack Penetration Test and Vulnerability Analysis,» *International Journal of Online Engineering (iJOE),* vol. 13(01), pp. 125-132, 2017.

[5] https://www.metasploit.com/, «Metasploit Framework User Guide» Version 3.1 [En línea]. Available: http://cs.uccs.edu/~cs591/metasploit/users_guide3_1.pdf. [Último acceso: 5 Septiembre 2018].

[6] Blogger, «Ataques de diccionario, ataques de fuerza bruta, programas, diccionarios» [En línea]. Available: https://inforseguridad.wordpress.com/2016/11/21/ataques-de-diccionario-ataques-de-fuerza-bruta-programas-diccionarios/. [Último acceso: 5 Septiembre 2018].

[1] La ingeniería social es un conjunto de técnicas que usan los cibercriminales para engañar a los usuarios incautos para que les envíen datos confidenciales, infecten sus computadoras con malware o abran enlaces a sitios infectados. Además, los hackers pueden tratar de aprovecharse de la falta de conocimiento de un usuario; debido a la velocidad a la que avanza la tecnología, numerosos consumidores y trabajadores no son conscientes del valor real de los datos personales y no saben con certeza cuál es la mejor manera de proteger esta información. Tomado de: https://latam.kaspersky.com/resource-center/definitions/what-is-social-engineering

[2] Por ejemplo, no buscar Facebook en el navegador web. Escribir el enlace www.facebook.com previene de entrar en páginas clonadas que roban información para acceder a la información del usuario.

[3] No se debe escribir contraseña el número de identificación, una fecha de preferencia o un nombre de algún familiar. Las contraseñas seguras combinan letras con números y símbolos para poder prevenir un desciframiento por fuerza bruta. Ejemplo de una contraseña segura: oxTU&5EWLToa12

Jhon Edison Duarte Pineda: Estudiante de ingeniería en Sistemas, Universidad Autónoma de Bucaramanga (UNAB). Tecnólogo en mantenimiento de equipos de cómputo y diseño e instalación de cableado estructurado (Sena – 2016). Cuarto puesto en evento de divulgación tecnológica SENASOFT 2015 en la categoría "Instalación y Hardening de Sistemas Operativos".